Defender for Office 365 (Plan 2) — Threat Explorer, Attack Simulation & Automated Investigation

Implementation Solution Guide

Version 1.0.0 · 2026-07-10

Contents

Executive Summary — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation 5

The problem . . . 5

The solution . . . 5

How it works . . . 5

Why it matters . . . 6

Important boundaries . . . 6

Solution Overview — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation 6

What this is . . . 6

How the technology works (the mental model) . . . 7

The standard deployment model . . . 7

Scope — what this solution covers . . . 8

Out of scope (handled elsewhere) . . . 8

Authentication and connections used . . . 9

Requirements — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation 9

R1. Defender for Office 365 **Plan 2** licensing . . . 9

R2. The prevention layer is already in place (the companion solution) . . . 10

R3. Roles to hunt, simulate, investigate, and remediate . . . 10

R4. A defined pilot group . . . 10

R5. A written simulation and communications plan . . . 11

R6. An agreed remediation and AIR-automation posture . . . 11

R7. The PowerShell + hunting toolchain . . . 11

Global Requirements — Defender (category-level) 12

G1. Microsoft 365 / Entra tenant . . . 12

G2. Defender licensing . . . 12

G3. Administrative roles (least privilege) . . . 12

G4. Onboarding reach to endpoints / identity / workloads . . . 12

G5. Network access to Defender service endpoints . . . 13

G6. A pilot ring . . . 13

G7. Log Analytics workspace (where required) . . . 13

G8. Response governance . . . 13

Implementation — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation 13

Phase 0 — Assess (read-only, changes nothing) . . . 14

Phase 1 — Configure (build the objects; nothing org-wide yet) . . . 15
Phase 2 — Pilot (run against the pilot group only) . . . 16
Phase 3 — Validate . . . 17
Phase 4 — Expand . . . 17
Rollback / safe-off . . . 18
Testing & Validation — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation 18
Gate 1 — Plan 2 is licensed and the features are present . . . 18
Gate 2 — The prevention layer is in place (dependency) . . . 18
Gate 3 — Email Advanced Hunting tables have data . . . 19
Gate 4 — The pilot simulation ran and reported . . . 19
Gate 5 — Post-delivery hunting returns results . . . 19
Gate 6 — AIR actions are **pending approval, not auto-applied** . . . 19
Gate 7 — Remediation preview is accurate and gated . . . 19
Gate 8 — The custom detection exists in alert-only mode . . . 20
Gate 9 — Roles and audit are correct . . . 20
Troubleshooting — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation 21
1. "Explorer" is missing — I only see "Real-time detections" . . . 21
2. Attack Simulation Training blade is absent or greyed out . . . 21
3. Advanced Hunting email tables return nothing (EmailEvents empty) . . . 21
4. A hunting query errors ("unknown table/column") . . . 22
5. AIR opened an investigation but **auto-deleted** mail during the pilot . . . 22
6. AIR actions never appear for approval . . . 22
7. `DEFMDOP2-Remediate.ps1` "won't do anything" . . . 22
8. Simulated phish was blocked / never delivered to targets . . . 22
9. Attack-simulation report is empty from PowerShell but present in the portal . . . 23
10. Graph/EXO connection or permission errors . . . 23
Best Practices — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation 23
Hunt on a question, not a hunch . . . 23
Simulate to measure, train to fix — never to punish . . . 23
Automate response only after you trust it . . . 24
Make detections durable . . . 24
Run it as a program, and watch the trend . . . 24
Where to go next . . . 24
Deliverables Summary — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation 25

Documentation 25
PowerShell tools (5) 26
Named objects (verbatim — used across docs, scripts, and tests) 27
What this solution deliberately does NOT do 27
How it is delivered 28
Appendix A — PowerShell Scripts 29

Executive Summary — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation

The problem

Blocking spam and known malware at the gateway is table stakes — and it is only half of email security. The threats that matter most are the ones that **land in a mailbox anyway**: a convincing credential-harvesting page a user clicks an hour after delivery, a payload that is weaponized after it arrived clean, a targeted phish that slips past the filter. Organizations that own **Defender for Office 365 Plan 2** usually run only its *prevention* half and leave its detection-and-response half switched off. The result is a predictable set of gaps:

• **No post-delivery visibility.** Once mail is delivered, no one can quickly answer "who else got this?", "who clicked?", or "is it still in inboxes?" — so cleanup is manual, slow, and incomplete.

• **Untrained users.** The single most-exploited control — the human — is never safely tested, so there is no measured picture of who is susceptible and no targeted training to fix it.

• **Manual, inconsistent response.** Removing a malicious message from dozens of mailboxes is done by hand, one investigation at a time, with no repeatable playbook and no approval trail.

The solution

This solution turns on and operationalizes the **detect / hunt / simulate / auto-respond** half of Defender for Office 365 Plan 2 — the value that lives *after* delivery. It:

• **Stands up Threat Explorer / Real-time detections** so you can hunt post-delivery email threats — pivot on sender, URL, file, or click, and see exactly who received and who interacted.

• **Runs Attack Simulation Training** — safe, benign phishing campaigns that measure who is susceptible and auto-assign targeted training, with user-risk reporting to track improvement.

• **Enables Automated Investigation & Response (AIR)** — alert-triggered investigations that gather evidence and *recommend* remediation, held behind **explicit approval** until you trust them.

• **Provides an email Advanced Hunting query library and custom detections** — reusable KQL over the email tables to find threats the built-in alerts miss.

• **Makes remediation deliberate** — soft-delete, hard-delete, and ZAP-style purge actions run through the **Action center with approval gates**, never silently.

How it works

We follow the same repeatable model every solution in this program uses — **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**. We first inventory what Plan 2 features are licensed and available, then configure Explorer, a first Attack Simulation campaign, and AIR in an **approval-required** posture, run

everything against a small **pilot group** first, validate that hunting works and remediation is gated, and only then expand across the organization. Nothing disruptive — no simulation to all staff, no automated deletion — happens before it is trusted.

The solution ships as **self-guided, click-by-click documentation plus five PowerShell tools** (Microsoft.Graph security + Exchange Online / Security & Compliance) and a **KQL hunting library** that inventory Plan 2 readiness, run email Advanced Hunting, report post-delivery threats and attack-simulation user risk, validate the configuration against pass/fail gates, and **preview** remediation actions — all **read-only or preview-first**, with **no credentials in code**.

Why it matters

- **You see what happens after delivery** — who received it, who clicked, whether it is still in inboxes — in minutes instead of a manual mailbox-by-mailbox hunt.
- **Your users get measurably safer** — real susceptibility data and targeted training instead of a once-a-year slideshow.
- **Response is fast but controlled** — repeatable, approval-gated remediation with an audit trail, not ad-hoc deletions.
- **A fraction of consulting cost** — the same disciplined method a Defender specialist would use, delivered as a repeatable, tested runbook.

Important boundaries

This is the **post-delivery detect / hunt / simulate / respond** layer of Defender for Office 365. It **deliberately does not cover** anti-spam, anti-malware, anti-phishing policy, Safe Links / Safe Attachments, connection filtering, or mail-flow hygiene — that **prevention** layer is the companion *Microsoft 365 Mail Hygiene: Anti-Spam, EOP & Defender for Office 365* solution, which this one assumes is already in place and **cross-references rather than repeats**. It **requires Defender for Office 365 Plan 2** (Threat Explorer, Attack Simulation Training, AIR, and the email Advanced Hunting tables are Plan 2 features) — *verify current availability and licensing in your tenant*. It provides the **technical controls**, not the **decisions**: which users to simulate, what counts as acceptable click-rate, and every production remediation approval are the customer's security-operations calls. Feature names, automation behavior, and table schemas **evolve and can differ by cloud (Commercial vs GCC / GCC High)** — *verify current availability in your tenant*.

Solution Overview — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation

What this is

A complete, self-guided method for turning on and operationalizing the **post-delivery detection and response** half of **Defender for Office 365 Plan 2** — Threat Explorer / Real-time detections, Attack Simulation Training, Automated Investigation & Response (AIR), email Advanced Hunting, and

approval-gated remediation.

It is the **detect / hunt / simulate / respond** layer of email security. It **assumes the prevention layer already exists** — anti-spam, anti-malware, anti-phishing, Safe Links, Safe Attachments and mail-flow hygiene are the companion *Microsoft 365 Mail Hygiene: Anti-Spam, EOP & Defender for Office 365* solution — and builds the hunting, training, and response capability on top of it. This solution never re-configures the prevention policies; it references them.

How the technology works (the mental model)

- **Threat Explorer / Real-time detections.** The interactive hunting surface for email. **Real-time

detections **(available with Plan 1) shows near-live detections;** Threat Explorer **(Plan 2) adds a richer, longer-retention view and lets you pivot on** sender, recipient, subject, URL, file hash, delivery location, and click verdict**, and** take action** on the results (submit, move, delete). It answers "who else got this, who clicked, is it still in inboxes?" — *verify current Explorer vs Real-time detections capabilities for your plan and cloud.*

- **Attack Simulation Training.** A Plan 2 feature that sends **benign, controlled** simulated

phishing (credential harvest, malware attachment, link-in-attachment, drive-by, OAuth consent) to chosen users, measures who is **compromised** (clicked / entered credentials / granted consent), and **auto-assigns targeted training**. It produces a **user-risk / repeat-offender** picture over time. Simulations are safe by design and do not deliver real payloads.

- **Automated Investigation & Response (AIR).** When certain email alerts fire (e.g. a user reported

a phish, or a URL was found malicious after delivery), AIR **automatically opens an investigation**, correlates the evidence (all copies of the message, who clicked, related entities), and produces **recommended remediation actions**. In an **approval-required** posture those actions wait in the **Action center** for a human to approve — nothing is deleted automatically until you decide to trust it. *Automation levels and defaults evolve — verify current behavior in your tenant.*

- **Email Advanced Hunting.** A Defender XDR query surface (KQL) over email tables — `EmailEvents`,

`EmailAttachmentInfo`, `EmailUrlInfo`, `EmailPostDeliveryEvents`, `UrlClickEvents` — for proactive hunting beyond the built-in alerts, and for building **custom detection rules**. Email tables require Defender for Office 365 Plan 2 — *verify table availability in your tenant*.

- **Remediation actions (soft/hard delete, ZAP).** The response verbs applied to malicious mail:

soft delete (to Deleted Items, recoverable), **hard delete** (purged), **move to junk**, and **Zero-hour Auto Purge (ZAP)**-style retroactive removal of already-delivered mail. Here these run as **manual or AIR-recommended actions routed through the Action center with approvals** — the ZAP *policy toggle* itself lives in the prevention solution; this solution governs using ZAP-style purge as a **deliberate response action**.

- **Action center.** The single approval queue for AIR-recommended and manually-submitted actions —

the control point where a human approves, rejects, or reviews every remediation, with an audit trail.

The standard deployment model

Every solution in this program follows the same five stages:

1. **Assess.** Confirm Plan 2 is licensed and the features are available; inventory current AIR posture, Explorer access, Attack Sim readiness, and email-table freshness (run `DEFMDOP2-Discovery.ps1`). Confirm the prevention layer is already in place.

1. **Configure.** Create the pilot group `Grp-MDO-Pilot-Users`; set AIR to an **approval-required** posture; save the hunting view `Explorer-PostDelivery-Pilot`; import the KQL hunting library; stage the first simulation `Sim-CredHarvest-Pilot` and training `Training-PhishAware-Pilot` — but do not launch org-wide.

1. **Pilot.** Run the simulation and hunting **against** `Grp-MDO-Pilot-Users` **only**; let AIR open investigations and **hold their actions in the Action center** for approval; practice a gated remediation with `Remediation-PhishBatch-Pilot` in **preview** (`DEFMDOP2-Remediate.ps1 -WhatIf`).

1. **Validate.** Confirm hunting returns results, simulation reporting works, AIR actions are **pending approval (not auto-applied)**, and remediation preview is accurate (run `DEFMDOP2-Validate.ps1`, `DEFMDOP2-Report.ps1`).

1. **Expand.** Widen the simulation to the organization (`Sim-CredHarvest-Org`), promote the tuned custom detection `Detect-PostDeliveryPhish-Pilot`, and decide — **as a documented operations decision** — whether to raise AIR automation from approval-required to a higher level.

Scope — what this solution covers

• **Threat Explorer / Real-time detections** — post-delivery email threat hunting and take-action.

• **Attack Simulation Training** — campaigns, susceptibility measurement, auto-assigned training, and user-risk reporting.

• **Automated Investigation & Response (AIR)** — alert-triggered investigations in an approval-required posture, with Action center approvals.

• **Email Advanced Hunting** — a reusable KQL query library and custom detections over the email tables.

• **Remediation actions** — soft-delete / hard-delete / ZAP-style purge run **through approvals**, previewed before execution.

Out of scope (handled elsewhere)

• **Anti-spam, anti-malware, anti-phishing policy, Safe Links, Safe Attachments, connection filtering, and mail-flow hygiene **— the** prevention** layer, delivered by the companion *Microsoft 365 Mail Hygiene: Anti-Spam, EOP & Defender for Office 365* solution. This solution assumes it is in place and does not re-configure it.

• **Endpoint, identity, and cloud-app detection/response** — Defender for Endpoint, Defender for Identity, and Defender for Cloud Apps are separate catalog solutions; this is email-focused.

• **SIEM correlation and SOAR** — exporting these detections to Microsoft Sentinel and building playbooks is the Sentinel catalog area.

• **The security-operations decisions** — which users to simulate, acceptable click-rate targets, the AIR automation level, and every production remediation approval are **the customer's SOC / security-leadership determinations**; this solution provides the technical controls and the data.

Authentication and connections used

• **Microsoft Defender portal** (`security.microsoft.com`) for Explorer, Attack Simulation Training, Action center, Advanced Hunting, and AIR settings.

• **PowerShell** with **Microsoft.Graph** (security endpoints — advanced hunting via `Security.runHuntingQuery`, and attack-simulation reporting where available — *some endpoints are beta; verify*) and **Exchange Online Management** / **Security & Compliance PowerShell** (Connect-ExchangeOnline / Connect-IPPSSession) for MDO reporting cmdlets.

• **KQL** run against the email Advanced Hunting tables for hunting, reporting, and custom detection.

• All tools authenticate **interactively** with an MFA-capable admin; **no credentials are stored in code**. Government-cloud tenants pass the matching endpoints — *verify endpoints for your cloud*.

Requirements — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation

These are the **solution-specific** prerequisites for standing up the post-delivery detect / hunt / simulate / respond capability. The **category baseline** — an active Microsoft 365 / Entra tenant, Defender licensing in general, least-privilege admin roles, onboarding reach, network access to Defender endpoints, a pilot ring, a workspace where required, and response governance — is covered once in `global-requirements-defender.md` (**G1–G8**). Read that first; the items below layer on top of it and are not repeated here.

Each requirement is stated as **Description / Why required / How to verify / How to implement if missing**.

R1. Defender for Office 365 Plan 2 licensing

• **Description:** Defender for Office 365 **Plan 2** assigned to the users in scope (bundled in Microsoft 365 E5 / Office 365 E5, E5 Security, or as an add-on). Plan 2 is what gates **Threat Explorer**, **Attack Simulation Training**, **AIR**, and the **email Advanced Hunting tables**.

• **Why required:** Plan 1 provides Real-time detections and the prevention features, but the hunting depth, simulation, automated investigation, and email hunting tables in this solution are **Plan 2** capabilities. Without Plan 2 the features are absent or limited.

• **How to verify:** Microsoft 365 admin center → **Billing** → **Licenses** shows a plan that includes

MDO Plan 2; in `security.microsoft.com` the **Attack simulation training** and **Explorer** blades are present. Or run `DEFMDOP2-Discovery.ps1`, which reports Plan 2 service-plan presence and feature availability. *Verify current availability and exact plan mapping in your tenant.*

• **How to implement if missing:** Assign MDO Plan 2 (or an E5 bundle that includes it) to the users in scope, then allow time for the features to surface. Do not proceed against Plan 1 only.

R2. The prevention layer is already in place (the companion solution)

• **Description:** Anti-spam, anti-malware, anti-phishing, **Safe Links**, **Safe Attachments**, connection filtering, and ZAP **policy** settings are configured — the *Microsoft 365 Mail Hygiene: Anti-Spam, EOP & Defender for Office 365* companion solution.

• **Why required:** This solution is the **post-delivery** half. Hunting, simulation, and AIR assume the preset/custom protection policies exist and are generating the signal (Safe Links click data, ZAP verdicts, detonation results) that Explorer and Advanced Hunting surface.

• **How to verify:** In `security.microsoft.com` → **Email & collaboration → Policies & rules → Threat policies**, confirm anti-phishing, anti-malware, anti-spam, Safe Links and Safe Attachments policies exist (or a Preset security policy is enabled).

• **How to implement if missing:** Deploy the prevention layer first (the companion solution). This solution does **not** configure those policies and depends on them being present.

R3. Roles to hunt, simulate, investigate, and remediate

• **Description: Security Administrator** (or the granular Defender RBAC equivalents) for configuration; **Security Operator / Security Reader** for analysts who hunt and triage; and the rights to approve actions in the **Action center**. Attack Simulation Training and remediation approvals are privileged actions.

• **Why required:** Explorer take-action, launching simulations, changing AIR posture, and approving remediation are all elevated operations; least-privilege keeps who-can-delete-mail small.

• **How to verify:** Entra → **Roles and administrators**, or the Defender portal **Permissions & roles**, show the operating accounts hold the required roles.

• **How to implement if missing:** Assign the roles at the appropriate scope (prefer **PIM-eligible** for the administrator role where Entra ID P2 is available — *verify licensing*). Reserve broad roles for named operators only.

R4. A defined pilot group

• **Description:** A named group of pilot users — `Grp-MDO-Pilot-Users` — to receive the first simulation, be the initial hunting/remediation scope, and validate AIR behavior before org-wide rollout. Ideally a mix of roles, but **not** high-risk executives for the very first simulation unless leadership approves.

• **Why required:** Simulations, AIR, and remediation are validated on a ring first (category **G6**).

A first simulation aimed at everyone, or a remediation practiced on production mail, is avoidable risk.

• **How to verify:** The group exists in Entra with the intended members; it is selectable as a simulation target and hunting filter.

• **How to implement if missing:** Create `Grp-MDO-Pilot-Users` in Entra and populate it with a representative, consented pilot cohort.

R5. A written simulation and communications plan

• **Description:** A short, **leadership-approved** plan covering **who** gets simulated, **when**, **how results are used** (training, not punishment), whether **HR / works councils / employee representatives** must be informed, and any **regional legal constraints** on simulating employees.

• **Why required:** Phishing simulation touches employees and, in some jurisdictions, employment and privacy law. How simulation data is used is a **people and compliance decision**, not a technical default.

• **How to verify:** Confirm a written, approved plan exists and names an owner.

• **How to implement if missing:** Facilitate a short session with security leadership and HR to agree scope, cadence, communications, and the non-punitive use of results. *Employee-simulation legality and works-council notification are the customer's HR/legal determinations — the solution provides the technical capability, not the decision.*

R6. An agreed remediation and AIR-automation posture

• **Description:** A written position on **how remediation is approved** (who may approve soft-delete vs hard-delete), and the **AIR automation level** the organization will start at (this solution starts **approval-required**) and the criteria to raise it later.

• **Why required:** Remediation deletes mail and AIR can act automatically; the organization must decide the guardrails (category **G8**). Hard-delete is irreversible and must be a deliberate, approved action.

• **How to verify:** A documented response/approval policy exists; AIR is in an approval-required posture; hard-delete requires a named approver.

• **How to implement if missing:** Define the approval matrix and start AIR approval-required. Raising automation is a **documented operations decision** made after the pilot builds trust — not a default this solution flips.

R7. The PowerShell + hunting toolchain

• **Description:** A workstation with **Microsoft.Graph** (security modules), **Exchange Online Management (`Connect-ExchangeOnline`, and `Connect-IPPSSession` for Security & Compliance cmdlets), signed in with an MFA-capable admin; and access to** Advanced Hunting** in the Defender portal for the KQL library.

• **Why required:** The five delivered tools use these modules and KQL to inventory Plan 2 readiness,

run email hunting, report threats and simulation risk, validate configuration, and **preview** remediation.

- **How to verify:** `Get-Module Microsoft.Graph, ExchangeOnlineManagement -ListAvailable` returns

versions; `Connect-MgGraph` and `Connect-ExchangeOnline` succeed; Advanced Hunting loads in the portal.

- **How to implement if missing:** `Install-Module Microsoft.Graph, ExchangeOnlineManagement -Scope

CurrentUser`; sign in. For Government cloud, connect with the matching environment/endpoints — *verify the correct endpoints for your cloud*. Some Graph attack-simulation endpoints are **beta** — *verify current availability before relying on them*.

Global Requirements — Defender (category-level)

These requirements apply to every solution in the Defender category (Microsoft Defender XDR and Defender for Cloud). Published once at the category level so listings stay small. Confirm before deploying any Defender solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *Defender changes touch detection and response for the whole tenant. Onboard in a ring (pilot devices/users first), keep automated response in an approval/simulate posture until trusted, and never disable an existing control to "test."*

G1. Microsoft 365 / Entra tenant

Description: An active Microsoft 365 tenant with Entra ID. Why: Defender XDR services and the unified portal (security.microsoft.com) are tenant workloads. Verify: Sign in to `https://security.microsoft.com` as an administrator. Implement: Provision a Microsoft 365 tenant and confirm Entra ID identities exist.

G2. Defender licensing

Description: The Defender plans for the pillars in scope — e.g. Defender for Endpoint P1/P2, Defender for Identity, Defender for Office 365 P1/P2, Defender for Cloud Apps, and Defender for Cloud plans. Why: Each pillar/feature is license-gated; onboarding without the plan fails or silently limits features. Verify: Admin center -> `Billing -> Licenses` (or the Defender portal). *Confirm the exact plan each feature needs — verify current availability in your tenant.* Implement: Assign the required plans (often bundled in M365 E5 / E5 Security) before onboarding.

G3. Administrative roles (least privilege)

Description: Security Administrator (and Global Administrator for first-time service activation). Why: Onboarding, RBAC, and policy changes in the Defender portal require these roles. Verify: Entra -> `Roles and administrators`; confirm Security Administrator. Implement: Assign Security Administrator; reserve Global Administrator for one-time activations.

G4. Onboarding reach to endpoints / identity / workloads

Description: A management channel to onboard the pillars — Intune/Configuration Manager/GPO/script for endpoints, domain controllers/AD FS for Identity sensors, and cloud connectors for Defender for Cloud. Why: Each pillar collects signal from a source that must be reachable and instrumented. Verify: Endpoints are managed (Intune/CM); DCs are reachable; cloud subscriptions are connected. Run the solution's discovery script. Implement: Establish the onboarding channel per pillar (see the relevant catalog endpoint/identity solutions).

G5. Network access to Defender service endpoints

Description: Outbound HTTPS to the Microsoft Defender / Microsoft 365 service URLs from onboarded assets. Why: Sensors and agents report to the cloud service; blocked endpoints break onboarding and detections. Verify: Confirm the documented Defender endpoint URLs/IP ranges are allowed. *Verify current endpoint list.* Implement: Allow the Defender/M365 endpoints through proxy/firewall.

G6. A pilot ring

Description: A defined set of pilot devices/users/subscriptions to onboard first. Why: XDR onboarding and automated response are validated on a ring before tenant-wide rollout. Verify: A pilot group exists in Entra/Intune. Implement: Create the pilot ring before enabling anything that acts automatically.

G7. Log Analytics workspace (where required)

Description: A Log Analytics workspace for Defender for Cloud / advanced hunting export where used. Why: Some Defender data and continuous export land in a workspace. Verify: A workspace exists and is access-controlled. Run the discovery script. Implement: Provision a workspace (or reuse the SIEM/observability one) with least-privilege access.

G8. Response governance

Description: An agreed position on automated response (auto-remediation levels, approval requirements). Why: XDR/AIR can take disruptive actions (isolate, delete, disable); the organization must decide the guardrails. Verify: A documented response policy exists; automation is in an approval/simulate posture until trusted. Implement: Define response guardrails; keep AIR/automation approval-gated at first. *Incident-response decisions are the SOC/security team's; this guide covers the technical configuration.*

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

Implementation — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation

This is the exact, ordered build. Every object you create is **named** with a consistent convention — `<Purpose> – <Scope> – <Stage>` — and the same name is reused in later steps, testing, and the scripts. Do the pilot phases against `Grp-MDO-Pilot-Users` before anything organization-wide.

> ***Before you start:*** *confirm the prevention layer is already deployed (**R2**) and Plan 2 is licensed (**R1**). This solution does **not** configure anti-spam / anti-phishing / Safe Links / Safe Attachments — it hunts, simulates, and responds on top of them.*

Named objects created in this guide (verbatim — reused everywhere):

Object	Name	What it is
Pilot user group	`Grp-MDO-Pilot-Users`	Entra security group — first simulation + hunting/remediation scope
Explorer saved view	`Explorer-PostDelivery-Pilot`	Saved Threat Explorer query for post-delivery hunting
Simulation (pilot)	`Sim-CredHarvest-Pilot`	First Attack Simulation campaign, pilot group only
Training assignment	`Training-PhishAware-Pilot`	Targeted training auto-assigned to those compromised
Custom detection	`Detect-PostDeliveryPhish-Pilot`	Advanced Hunting custom detection rule
Remediation batch	`Remediation-PhishBatch-Pilot`	Approval-gated response action set
Simulation (org wave)	`Sim-CredHarvest-Org`	Organization-wide simulation, created only at Expand

Phase 0 — Assess (read-only, changes nothing)

Step 0.1 — Confirm Plan 2 features are present

1. Sign in to the **Microsoft Defender portal** → `https://security.microsoft.com` as a Security Administrator.

1. Confirm these blades are visible:

• **Email & collaboration** → **Explorer** (Threat Explorer). *If you see only "Real-time detections" you are on Plan 1 — verify licensing (R1).*

• **Email & collaboration** → **Attack simulation training.**

• **Actions & submissions** → **Action center.**

• **Investigation & response** → **Hunting** → **Advanced hunting.**

1. Run the discovery script to inventory readiness from PowerShell:

```
pwsh -File .\DEFMDOP2-Discovery.ps1 -PilotGroup "Grp-MDO-Pilot-Users"
```

It reports Plan 2 service-plan presence, whether the email Advanced Hunting tables have recent data, current AIR/automation posture where readable, and any actions already pending in the Action center. **Read-only.**

Step 0.2 — Confirm the prevention layer exists

1. Go to **Email & collaboration** → **Policies & rules** → **Threat policies**.

2. Confirm anti-phishing, anti-malware, anti-spam, **Safe Links**, and **Safe Attachments** policies exist (or a **Preset security policy** is Standard/Strict enabled). **Do not edit them here** — they belong to the prevention (companion) solution. You are only confirming the signal source.

Phase 1 — Configure (build the objects; nothing org-wide yet)

Step 1.1 — Create the pilot group

1. In **Entra admin center** (`entra.microsoft.com`) → **Groups** → **New group**.
2. Type **Security**; **Name** `Grp-MDO-Pilot-Users`; add a representative, **consented** set of pilot users (avoid top executives for the very first simulation unless leadership approves — R4).
1. Save. This group is the target for the pilot simulation and the scope for pilot hunting and remediation.

Step 1.2 — Set AIR to an approval-required posture

1. In the Defender portal → **Settings → Email & collaboration → (Automation / Advanced automation settings)** — *exact path evolves; verify current location in your tenant.*
1. Confirm **Automated Investigation & Response** is **enabled** but configured so that recommended remediation actions **require approval** (they land in the Action center rather than auto-apply). The goal for the pilot is: **AIR investigates automatically, a human approves every action.**
1. Record the current setting so you can prove (in testing) that actions are pending, not applied.

Step 1.3 — Save the post-delivery hunting view in Explorer

1. Go to **Email & collaboration** → **Explorer**.
2. Set the view to **All email** (or **Phish** / **Malware** as needed), set the time range, and add filters that represent your standard post-delivery hunt — e.g. **Delivery action = Delivered**, **Detection technology**, and a **URL click verdict** column.
1. Save the query as `Explorer-PostDelivery-Pilot` (Explorer supports saving/sharing queries — *verify current save/track behavior in your tenant*). This is the reusable starting point for post-delivery hunts.

Step 1.4 — Import the email Advanced Hunting query library

1. Go to **Investigation & response** → **Hunting** → **Advanced hunting**.
2. Paste each query from the delivered KQL library (surfaced by `DEFMDOP2-Hunt.ps1`) — for example:

• **Post-delivery malicious URL clicks** — join `UrlClickInfo` / `UrlClickInfo`-style click data to `EmailUrlInfo` and `EmailEvents` to find users who **clicked after delivery**.

• **Recipients of a known-bad sender/subject** — `EmailEvents` filtered to a campaign indicator.

• **Attachments matching a known-bad hash** — `EmailAttachmentInfo` joined to `EmailEvents`.

Table/column names evolve — verify against your tenant's schema.

1. **Save** the most useful queries to your shared queries so the team reuses them.

Step 1.5 — Stage (but do not launch) the first simulation

1. Go to **Email & collaboration** → **Attack simulation training** → **Simulations** → **Launch a simulation**.
2. **Technique:** choose **Credential Harvest** for the first run (lowest-risk, highest-signal).
3. **Name:** `Sim-CredHarvest-Pilot`.
4. **Target users:** select `Grp-MDO-Pilot-Users` only.
5. **Payload:** choose a built-in benign payload (or a globally provided one). Do **not** craft one

that impersonates a real internal person or brand without approval.

1. **Training:** enable **assign training** and configure the training assignment

`Training-PhishAware-Pilot` to auto-assign to users who are compromised.

1. **Schedule:** set a launch time but keep the campaign in a **staged / scheduled** state until the

communications plan (R5) is confirmed. **Do not launch yet.**

Phase 2 — Pilot (run against the pilot group only)

Step 2.1 — Launch the pilot simulation

1. With the communications/HR plan (R5) confirmed, launch `Sim-CredHarvest-Pilot` to

`Grp-MDO-Pilot-Users`.

1. Let it run its window. As users interact, Attack Simulation Training records **compromise** and

auto-assigns `Training-PhishAware-Pilot`.

Step 2.2 — Hunt post-delivery on the pilot scope

1. Open `Explorer-PostDelivery-Pilot` and scope it to `Grp-MDO-Pilot-Users` recipients; review a

real or test post-delivery scenario (who received, who clicked, current delivery location).

1. Run the Advanced Hunting library from PowerShell:

```
pwsh -File .\DEFMDOP2-Hunt.ps1 -QuerySet PostDeliveryPhish -LookbackDays 7
```

It runs the KQL library via Graph and returns the recipients/clicks/attachments matching the indicators. **Read-only.**

Step 2.3 — Let AIR investigate, and hold actions for approval

1. Trigger an investigation the safe way — e.g. have a pilot user **Report** a test/benign message,

or use a submitted URL — so AIR opens an investigation.

1. Go to **Actions & submissions** → **Action center** → **Pending**. Confirm AIR's **recommended actions**

are **waiting for approval** (not applied). This proves the approval-required posture (Step 1.2).

Step 2.4 — Practice a gated remediation in preview (no deletion)

1. From a hunt result, build the response set and **preview** it — never delete blind:

```
pwsh -File .\DEFMDOP2-Remediate.ps1 -InputCsv .\hunt-results.csv `
     -Action SoftDelete -BatchName "Remediation-PhishBatch-Pilot" -WhatIf
```

With `-WhatIf` (the default posture) the script **only prints what it would do** — the messages, mailboxes, and action — and changes nothing.

1. To actually remediate, do it **through the Action center approval flow** (or re-run with the explicit `-Execute -Confirm` gate the script requires), starting with **SoftDelete** (recoverable) before ever considering **HardDelete**. Every execution is approved by a named operator (R6).

Step 2.5 — Build the custom detection (pilot)

1. In **Advanced hunting**, open the tuned post-delivery query and choose **Create detection rule**.
2. Name it `Detect-PostDeliveryPhish-Pilot`, set frequency and the impacted entities, and keep its response action to **generate an alert only** during the pilot (no automatic remediation).

Phase 3 — Validate

1. Run the validation script:

```
pwsh -File .\DEFMDOP2-Validate.ps1 -PilotGroup "Grp-MDO-Pilot-Users"
```

It checks the pass/fail gates in `05-testing.md`: Plan 2 present, email tables have data, the simulation ran and reported, AIR actions are **pending (not auto-applied)**, the custom detection exists in alert-only mode, and the remediation preview resolves.

1. Run the reporting script and review results with stakeholders:

```
pwsh -File .\DEFMDOP2-Report.ps1 -LookbackDays 30 -OutputCsv .\mdop2-report.csv
```

It reports post-delivery threat activity and the **attack-simulation user-risk / repeat-offender** picture. Do not expand until the gates pass and the reports look right.

Phase 4 — Expand

1. **Widen the simulation.** Create `Sim-CredHarvest-Org` targeting the broader organization (or the next ring), per the approved cadence in the communications plan (R5).

1. **Promote the custom detection.** Once `Detect-PostDeliveryPhish-Pilot` is proven quiet and accurate, widen its scope (and rename per your convention for production).

1. **Decide the AIR automation level — deliberately.** If the pilot has built trust, security operations may **document a decision** to raise AIR from approval-required to a higher automation level for specific, well-understood action types. This is an **operations decision (R6)**, made with rollback in mind — not a default this solution flips for you.

1. **Institutionalize the loop.** Schedule recurring hunts, simulations, and reporting, and keep hard-delete a named-approver-only action.

Rollback / safe-off

- **Simulation:** stop or cancel a running campaign in **Attack simulation training**; it delivers no real payload, so stopping it has no cleanup cost.
- **AIR / remediation:** because you started **approval-required** and previewed remediation with `-WhatIf`, nothing is auto-applied — reject pending actions in the Action center to "undo". A **SoftDelete** is recoverable from Deleted Items; **HardDelete** is not, which is why it is gated.
- **Custom detection:** disable `Detect-PostDeliveryPhish-Pilot` to stop it generating alerts.
- **Explorer / hunting:** read-only — nothing to roll back.

Testing & Validation — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation

Validate the build against explicit **pass/fail gates** before expanding beyond the pilot group. Run the two scripts and walk the manual checks. Do not proceed to **Expand** until every gate passes. The automated gates are produced by `DEFMDOP2-Validate.ps1`; reporting evidence comes from `DEFMDOP2-Report.ps1`, hunting from `DEFMDOP2-Hunt.ps1`, and readiness from `DEFMDOP2-Discovery.ps1`.

Each gate lists **What good looks like / How to test / If it fails**.

Gate 1 — Plan 2 is licensed and the features are present

- **What good looks like:** MDO Plan 2 is assigned to in-scope users; Explorer, Attack Simulation Training, Action center, and Advanced Hunting blades are all visible.
- **How to test:** Run `DEFMDOP2-Discovery.ps1`; confirm it reports the Plan 2 service plan present. In the portal confirm the four blades load (not just "Real-time detections").
- **If it fails:** Assign MDO Plan 2 (R1) and allow provisioning time; re-run discovery.

Gate 2 — The prevention layer is in place (dependency)

- **What good looks like:** Anti-phishing/-malware/-spam, Safe Links, and Safe Attachments policies (or an enabled Preset security policy) exist.
- **How to test: Email & collaboration** → **Policies & rules** → **Threat policies** lists them.
- **If it fails:** Deploy the companion *Mail Hygiene* prevention solution first; this solution depends on its signal.

Gate 3 — Email Advanced Hunting tables have data

- **What good looks like:** `EmailEvents` (and related email tables) return recent rows.
- **How to test:** In **Advanced hunting** run `EmailEvents | where Timestamp > ago(24h) | count`,

or read the freshness section of `DEFMDOP2-Discovery.ps1`. Rows return.

- **If it fails:** Confirm Plan 2 provisioned and mail is flowing; email tables are Plan 2 features —

verify table availability in your tenant.

Gate 4 — The pilot simulation ran and reported

- **What good looks like:** `Sim-CredHarvest-Pilot` completed against `Grp-MDO-Pilot-Users`, with

per-user compromise results and `Training-PhishAware-Pilot` auto-assigned to those compromised.

- **How to test: Attack simulation training** → **Simulations** shows the campaign complete with a

report; `DEFMDOP2-Report.ps1` returns the user-risk summary.

- **If it fails:** Confirm the campaign launched (not just staged), the target group was correct, and

training assignment was enabled (Step 1.5).

Gate 5 — Post-delivery hunting returns results

- **What good looks like:** `Explorer-PostDelivery-Pilot` and the KQL library return who received /

who clicked for a test or real post-delivery scenario.

- **How to test:** Run `DEFMDOP2-Hunt.ps1 -QuerySet PostDeliveryPhish`; it returns matching

recipients/clicks. The saved Explorer view loads and filters.

- **If it fails:** Check table freshness (Gate 3), the query filters, and hunting permissions (R3).

Gate 6 — AIR actions are pending approval, not auto-applied

- **What good looks like:** An AIR investigation opened, and its recommended remediation actions are

waiting in the Action center, not already executed.

- **How to test: Actions & submissions** → **Action center** → **Pending** shows the AIR-recommended

actions as pending. `DEFMDOP2-Validate.ps1` flags any action that was auto-applied during the pilot as a **FAIL**.

- **If it fails:** Set AIR back to approval-required (Step 1.2); the pilot must not auto-remediate.

Gate 7 — Remediation preview is accurate and gated

• **What good looks like:** `DEFMDOP2-Remediate.ps1 -WhatIf` prints exactly which messages/mailboxes

it would act on and **changes nothing**; execution requires the explicit `-Execute -Confirm` gate and/or Action center approval.

• **How to test:** Run the remediation script with `-WhatIf` against a hunt-result CSV; confirm no deletion occurred (the messages remain). Confirm the script refuses to act without the gate.

• **If it fails:** Do not run remediation until preview is correct; never run hard-delete blind.

Gate 8 — The custom detection exists in alert-only mode

• **What good looks like:** `Detect-PostDeliveryPhish-Pilot` exists as a custom detection rule that

generates an alert only (no automatic remediation) during the pilot.

• **How to test: Advanced hunting** → **Custom detection rules** lists it; its response action is alert-only. `DEFMDOP2-Validate.ps1` confirms.

• **If it fails:** Recreate the rule from the tuned query (Step 2.5) and set the response to alert-only.

Gate 9 — Roles and audit are correct

• **What good looks like:** Only named operators can launch simulations, change AIR posture, and approve remediation; every approval is auditable.

• **How to test:** Review **Permissions & roles** and confirm least-privilege (R3); confirm Action center approvals show who approved each action.

• **If it fails:** Tighten role assignments; prefer PIM-eligible for the administrator role where available.

Validation summary

Gate	Check	Pass condition
1	Plan 2 + features present	Plan 2 assigned; four blades visible
2	Prevention layer present	Threat policies / preset exist
3	Email tables have data	`EmailEvents` returns recent rows
4	Pilot simulation ran	`Sim-CredHarvest-Pilot` reported; training assigned
5	Hunting returns results	KQL library + `Explorer-PostDelivery-Pilot` return data
6	AIR pending, not auto-applied	Actions in Action center **Pending**

Gate	Check	Pass condition
7	Remediation preview gated	`-WhatIf` changes nothing; execution requires gate
8	Custom detection alert-only	`Detect-PostDeliveryPhish-Pilot` exists, alert-only
9	Roles + audit correct	Least-privilege; approvals audited

All nine gates pass ⇒ proceed to **Expand**. Any fail ⇒ stay in pilot and remediate the gate first.

Troubleshooting — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation

The common failure modes, each as **symptom** → **cause** → **fix**. Most issues are licensing, table freshness, or an approval-posture surprise — not a broken feature.

1. "Explorer" is missing — I only see "Real-time detections"

- **Symptom:** Under Email & collaboration there is **Real-time detections** but no **Explorer**.
- **Cause:** The tenant/user is on **Defender for Office 365 Plan 1**, not Plan 2. Threat Explorer is a Plan 2 feature.
- **Fix:** Verify licensing (R1) — assign MDO **Plan 2** to the users in scope and allow provisioning time. Confirm with `DEFMDOP2-Discovery.ps1`. *Verify current plan-to-feature mapping in your tenant.*

2. Attack Simulation Training blade is absent or greyed out

- **Symptom:** No **Attack simulation training** blade, or "not available".
- **Cause:** Missing Plan 2, or the feature is still provisioning, or the account lacks the role.
- **Fix:** Confirm Plan 2 (R1); wait for provisioning; confirm the account holds the required role (R3). *Feature availability can differ by cloud (GCC/GCC High) — verify.*

3. Advanced Hunting email tables return nothing (EmailEvents empty)

- **Symptom:** `EmailEvents | count` returns 0, hunts and reports come back empty.
- **Cause:** Plan 2 not provisioned, no mail flowing yet, or the table/column names differ in your cloud.
- **Fix:** Confirm Plan 2 and that mail is actually flowing; check freshness with `DEFMDOP2-Discovery.ps1`. If a query errors on a column, **verify the schema for your tenant/cloud** — Microsoft renames/reshapes hunting tables periodically.

4. A hunting query errors ("unknown table/column")

• **Symptom:** `DEFMDOP2-Hunt.ps1` or a portal query fails to resolve a table or column (e.g. `UrlClickInfo`, `IsClickedThrough`).

• **Cause:** Schema drift — the delivered KQL uses representative names that evolve.

• **Fix:** Open **Advanced hunting** → **schema** and correct the table/column to your tenant's current names; the library is a starting point, not a frozen contract. *Verify current schema.*

5. AIR opened an investigation but auto-deleted mail during the pilot

• **Symptom:** Mail was removed without anyone approving it.

• **Cause:** AIR automation is set **higher than approval-required**; the pilot should hold actions.

• **Fix:** Set AIR back to an **approval-required** posture (Step 1.2) so actions land in the **Action center → Pending**. `DEFMDOP2-Validate.ps1` **flags auto-applied actions as a FAIL. Only raise automation later as a** documented operations decision (R6)**.

6. AIR actions never appear for approval

• **Symptom:** Nothing shows in **Action center** → **Pending** even after an alert.

• **Cause:** AIR not enabled, no qualifying alert fired, or the account cannot see the Action center.

• **Fix:** Confirm AIR is enabled; trigger it the safe way (have a pilot user **Report** a test/benign message); confirm the account has rights to view/approve actions (R3).

7. `DEFMDOP2-Remediate.ps1` "won't do anything"

• **Symptom:** The script prints a preview and exits without remediating.

• **Cause: Working as designed.** Preview (`-WhatIf`) is the default; execution is double-gated.

• **Fix:** To act, re-run with `-Execute -Confirm` (and `-IUnderstandHardDelete` for hard-delete), then **approve the batch in the Action center**. Start with **SoftDelete** (recoverable) before ever using HardDelete. This gating is intentional — never wire it to run unattended.

8. Simulated phish was blocked / never delivered to targets

• **Symptom:** Users did not receive the simulation; results are empty.

• **Cause:** The simulation URLs/domains are not allowed for simulation, or advanced delivery isn't configured for the simulation source.

• **Fix:** Configure the **Advanced delivery** policy for third-party/simulation URLs so simulations bypass filtering as intended. *This is a prevention-layer setting — confirm it with the companion Mail Hygiene solution; verify current configuration steps.*

9. Attack-simulation report is empty from PowerShell but present in the portal

- **Symptom:** `DEFMDOP2-Report.ps1` shows no simulations, but the portal does.
- **Cause:** The Graph **attack-simulation endpoints are beta** and may be unavailable, permission-gated, or absent in your cloud.
- **Fix:** Use the portal report for authoritative per-user detail; grant `AttackSimulation.Read.All` where the beta API is available. *Verify current API availability for your cloud.* The script degrades gracefully by design.

10. Graph/EXO connection or permission errors

- **Symptom:** `Connect-MgGraph` / `Connect-ExchangeOnline` fails, or a call returns 403.
- **Cause:** Missing modules, wrong cloud endpoint, unconsented scopes, or insufficient role.
- **Fix:** `Install-Module Microsoft.Graph, ExchangeOnlineManagement`; connect with the correct `-Environment` for Government cloud; consent the read scopes listed in each script header; confirm the operating account holds the role (R3). *Verify the correct endpoints for your cloud.*

Best Practices — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation

Keep-it-clean guidance for a post-delivery detection-and-response practice that stays trusted, measured, and current over time.

Hunt on a question, not a hunch

- **Start every hunt from an answerable question** — "who else received this?", "who clicked after delivery?", "is it still in inboxes?" — and pivot in Explorer on the entity (sender, URL, hash, click verdict). Save the good hunts (`Explorer-PostDelivery-Pilot`, the KQL library) so the team reuses them instead of reinventing.
- **Prefer post-delivery signal.** The prevention layer already blocked the obvious; your value is in what got through and what changed after delivery (weaponized-after-delivery URLs, late clicks).
- **Re-hunt after every incident.** A new indicator (sender, domain, hash) is a new query — run it across the whole tenant, not just the reporting user.

Simulate to measure, train to fix — never to punish

- **Simulation is a measurement tool.** Its job is to produce **honest susceptibility data** and

route the right people to targeted training — not to embarrass anyone. Make the non-punitive intent explicit in the communications plan (R5); a punitive program destroys reporting culture.

- **Start easy, escalate slowly.** Begin with credential-harvest to the pilot group (`Sim-CredHarvest-Pilot`), then broaden technique and audience over time (`Sim-CredHarvest-Org`). Track the **repeat-offender** trend, not a single campaign's click rate.
- **Respect people and the law.** Whether, when, and how you simulate employees — and who must be informed — are **HR/legal decisions**. Get them agreed before you launch.

Automate response only after you trust it

- **Approval-required first.** Keep AIR in an **approval-required** posture and route remediation through the **Action center** until the pilot proves the recommendations are right. A human approves every deletion at first.
- **Soft before hard.** Prefer **soft-delete** (recoverable from Deleted Items) over **hard-delete** (irreversible). Make hard-delete a **named-approver-only** action, always previewed with `-WhatIf` before execution.
- **Raise automation deliberately.** Only lift AIR to a higher automation level as a **documented operations decision (R6)**, for specific well-understood action types, with rollback in mind — not because it is convenient.

Make detections durable

- **Custom detections earn their place.** Promote a hunting query to a custom detection (`Detect-PostDeliveryPhish-Pilot`) only once it is **quiet and accurate**; keep it alert-only until proven, then widen scope.
- **Version the good queries.** Keep your KQL library in source control so hunts are reviewable and portable — the same discipline the Sentinel detection-as-code solution applies.

Run it as a program, and watch the trend

- **Loop, don't launch-and-forget.** Hunt → simulate → train → investigate → (gated) remediate → report, on a cadence. Post-delivery threats and user behavior both drift.
- **Track the right signals.** A falling repeat-offender rate, faster time-to-remediate, and more threats caught post-delivery are the signs the program is working — report them to leadership.

Where to go next

With post-delivery detection and response operational, the natural next steps in this catalog are:

- **Microsoft 365 Mail Hygiene: Anti-Spam, EOP & Defender for Office 365** — the **prevention** layer this solution sits on top of; revisit it to tighten the policies that reduce what you have to hunt.

• **Microsoft Defender XDR** onboarding — bring endpoint, identity, and cloud-app detection into the same incident so email threats correlate with the rest of the kill chain.

• **Microsoft Sentinel analytics rules & SOAR** — export these email detections to the SIEM and build playbooks so trusted incidents drive automated response beyond the mailbox.

• **Entra ID conditional access & phishing-resistant authentication** — reduce the payoff of the credential-harvest that simulation keeps finding.

Deliverables Summary — Defender for Office 365 (Plan 2): Threat Explorer, Attack Simulation & Automated Investigation

Everything included in this solution, and what each piece is for.

Documentation

Document	Purpose
Executive Summary (`executive-summary.md`)	One-page business framing: the "spam-blocked-then-blind" problem, the post-delivery detect/hunt/simulate/respond solution, and the boundary (post-delivery only; prevention is the companion solution; requires Plan 2).
Solution Overview (`01-solution-overview.md`)	What it is, how the technology works (Explorer/Real-time detections, Attack Simulation Training, AIR, email Advanced Hunting, remediation actions, Action center), the Assess→Configure→Pilot→Validate→Expand model, scope, out-of-scope, and connections used.
Requirements (`02-requirements.md`)	Solution-specific prerequisites (Plan 2 licensing, the prevention layer already in place, hunt/simulate/remediate roles, a pilot group, a simulation + communications plan, a remediation/AIR-automation posture, the toolchain) — layered on the shared `global-requirements-defender.md` (G1–G8).
Implementation (`03-implementation.md`)	Exact, ordered build: assess Plan 2 readiness, create the pilot group, set AIR approval-required, save the Explorer view + KQL library, stage and pilot a simulation, hold AIR actions for approval, preview a gated remediation, build an alert-only custom detection, validate, then expand — every object named, with rollback.

Document	Purpose
Testing & Validation (`05-testing.md`)	Nine pass/fail gates from Plan-2-present and table-freshness through simulation-reported, hunting-returns-results, AIR-pending-not-auto-applied, remediation-preview-gated, and custom-detection-alert-only, referencing the scripts by name.
Troubleshooting (`06-troubleshooting.md`)	The common failure modes (Explorer missing, sim blade absent, empty email tables, schema drift, AIR auto-deleting, no pending actions, remediation "won't act", sim not delivered, beta API empty, connection errors) as symptom → cause → fix.
Best Practices (`07-best-practices.md`)	Hunt-on-a-question, simulate-to-measure-not-punish, automate-only-when-trusted, soft-before-hard, make-detections-durable, run-it-as-a-program — plus where to go next in the catalog.

PowerShell tools (5)

All tools are **read-only or preview-first**, authenticate **interactively** (no credentials in code), and use **Microsoft.Graph** (security — advanced hunting via `runHuntingQuery`, and attack-simulation **beta** reporting where available) and **Exchange Online / Security & Compliance** where relevant, with **KQL** over the email tables. Government-cloud tenants pass the matching environment — *verify endpoints for your cloud*.

Script	Type	What it does
`DEFMDOP2-Discovery.ps1`	Read-only	Inventories Plan 2 readiness: service-plan presence, email Advanced Hunting table freshness (`EmailEvents` etc.), pilot-group membership, and the Action center pending-actions posture. Changes nothing.
`DEFMDOP2-Hunt.ps1`	Read-only	Runs a curated email Advanced Hunting KQL library (post-delivery clicks, sender/subject campaign, bad-attachment hash) via Graph and returns matching recipients/clicks/attachments — the hunt that feeds a gated remediation preview.

Script	Type	What it does
`DEFMDOP2-Report.ps1`	Read-only	Reports post-delivery threat activity (delivered-then-detected phish/malware) and the Attack Simulation Training user-risk / repeat-offender picture; exports to CSV.
`DEFMDOP2-Validate.ps1`	Read-only	Runs the `05-testing.md` gates as PASS/FAIL/MANUAL lines: Plan 2 present, tables have data, pilot simulation reported, hunting resolves, AIR pending (not auto-applied), remediation preview gated, custom detection alert-only.
`DEFMDOP2-Remediate.ps1`	Preview-first (gated)	Turns a hunt-result CSV into a named remediation batch and **previews** it (`-WhatIf` default, changes nothing); execution is **double-gated** (`-Execute -Confirm`, plus `-IUnderstandHardDelete` for hard-delete) and routed through **Action center approval** — never unattended.

Named objects (verbatim — used across docs, scripts, and tests)

- **Pilot user group:** `Grp-MDO-Pilot-Users`
- **Explorer saved view:** `Explorer-PostDelivery-Pilot`
- **Simulations:** `Sim-CredHarvest-Pilot` (pilot), `Sim-CredHarvest-Org` (Expand)
- **Training assignment:** `Training-PhishAware-Pilot`
- **Custom detection rule:** `Detect-PostDeliveryPhish-Pilot` (alert-only during pilot)
- **Remediation batch:** `Remediation-PhishBatch-Pilot`

What this solution deliberately does NOT do

- It does **not** configure anti-spam, anti-malware, anti-phishing, Safe Links, Safe Attachments, or mail-flow hygiene — that **prevention** layer is the companion *Microsoft 365 Mail Hygiene: Anti-Spam, EOP & Defender for Office 365* solution, which this one depends on and cross-references.
- It does **not** auto-remediate during the pilot — AIR runs **approval-required** and remediation is **preview-first and double-gated**; hard-delete is a named-approver-only action.

• It does **not** decide **who to simulate, acceptable click-rate, or the AIR automation level** — those are HR/security-leadership determinations; the solution provides the controls and the data.

• It does **not** invent licensing, feature, or schema facts — where availability may differ by tenant/cloud (Plan 2 features, attack-simulation beta API, hunting-table schema) it says **verify in your tenant**.

How it is delivered

This solution is delivered as a **Complete Solution Package (PDF + Word + scripts)** — the documentation as a formatted Word document and PDF, plus all five PowerShell scripts, in a single ZIP (`DEFMDOP2-Complete-Solution.zip`) — yours to keep and reuse on every rollout.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

DEFMDOP2-Discovery.ps1

Purpose: Inventories the post-delivery readiness so the build starts from reality: whether the Defender for Office 365 Plan 2 service plan is assigned, whether the email Advanced Hunting tables have recent data, the current pilot-group membership, and how many actions are already pending in the Action center. Read-only — it changes nothing. HOW TO RUN pwsh -File .\DEFMDOP2-Discovery.ps1 -PilotGroup "Grp-MDO-Pilot-Users"

How to run: pwsh -File .\DEFMDOP2-Discovery.ps1 -PilotGroup "Grp-MDO-Pilot-Users"

DEFMDOP2-Hunt.ps1

Purpose: Runs a curated library of email-focused Advanced Hunting KQL queries via the Microsoft Graph security runHuntingQuery endpoint — post-delivery malicious clicks, recipients of a known-bad sender/subject, and attachments matching a known-bad hash — so hunting is repeatable instead of ad-hoc portal clicking. Read-only — it only queries. HOW TO RUN pwsh -File .\DEFMDOP2-Hunt.ps1 -QuerySet PostDeliveryPhish -LookbackDays 7 pwsh -File .\DEFMDOP2-Hunt.ps1 -QuerySet SenderCampaign -Indicator "badsender@contoso.com" pwsh -File .\DEFMDOP2-Hunt.ps1 -QuerySet BadAttachmentHash -Indicator "<sha256>"

How to run: pwsh -File .\DEFMDOP2-Hunt.ps1 -QuerySet PostDeliveryPhish -LookbackDays 7 pwsh -File .\DEFMDOP2-Hunt.ps1 -QuerySet SenderCampaign -Indicator "badsender@contoso.com" pwsh -File .\DEFMDOP2-Hunt.ps1 -QuerySet BadAttachmentHash -Indicator "<sha256>"

DEFMDOP2-Remediate.ps1

Purpose: Turns a hunt-result CSV (from DEFMDOP2-Hunt.ps1) into a named remediation batch and, by DEFAULT, only PREVIEWS it — printing exactly which messages/mailboxes/action it would submit and changing nothing. This is a deliberately gated change tool: it will NOT act unless you pass BOTH -Execute and -Confirm, and even then it submits through the tenant's approval flow (Action center) rather than deleting silently. Soft-delete is recoverable; hard-delete is not and is the most-gated path. HOW TO RUN Preview (safe default — no change): pwsh -File .\DEFMDOP2-Remediate.ps1 -InputCsv .\hunt-results.csv -Action SoftDelete ` -BatchName "Remediation-PhishBatch-Pilot" -WhatIf

How to run: Preview (safe default — no change): pwsh -File .\DEFMDOP2-Remediate.ps1 -InputCsv .\hunt-results.csv -Action SoftDelete ` -BatchName "Remediation-PhishBatch-Pilot" -WhatIf

DEFMDOP2-Report.ps1

Purpose: Produces two management-facing reports: (1) post-delivery threat activity over the window (delivered-then-detected mail, post-delivery clicks) via Advanced Hunting KQL, and (2) the Attack Simulation Training user-risk / repeat-offender picture (who was compromised, who was assigned training). Read-only — reporting only. HOW TO RUN pwsh -File .\DEFMDOP2-Report.ps1 -LookbackDays 30 -OutputCsv .\mdop2-report.csv

How to run: pwsh -File .\DEFMDOP2-Report.ps1 -LookbackDays 30 -OutputCsv .\mdop2-report.csv

DEFMDOP2-Validate.ps1

Purpose: Checks the build against the gates in 05-testing.md and prints PASS/FAIL per gate: Plan 2 present, email tables have data, a pilot simulation reported, hunting returns results, AIR actions are pending (not auto-applied), remediation preview is available/gated, and the custom detection exists in alert-only mode. Read-only — it validates, it does not change anything. HOW TO RUN pwsh -File .\DEFMDOP2-Validate.ps1 -PilotGroup "Grp-MDO-Pilot-Users"

How to run: pwsh -File .\DEFMDOP2-Validate.ps1 -PilotGroup "Grp-MDO-Pilot-Users"